

OFFSEC

PÓS-EXPLORAÇÃO



7

LISTA DE FIGURAS

Figura 1 - Permissões	14
Figura 2 - Bit Sticky	17
Figura 3 - sysinfo	18
Figura 4 - getuid	19
Figura 5 - enum_service	19
Figura 6 - PS	20
Figura 7 - Winenum	20
Figura 8 – Keylogger	21

SUMÁRIO

PÓS - EXPLORAÇÃO	4
1 INTRODUÇÃO	4
2 QUEBRA DE SENHA	5
2.1 Pós-exploração Windows	5
3 PÓS-EXPLORAÇÃO LINUX	12
4 DADOS CONFIDENCIAIS	18
4.1 Pilaging	18
REFERÊNCIAS	22

PÓS - EXPLORAÇÃO

1 INTRODUÇÃO

O Post Exploitation engloba todas as atividades que o pentester precisa realizar quando o sistema de destino for comprometido: determinar quanto a máquina é importante em sua infraestrutura de rede, manter o acesso, reunir informações e assim por diante. Em outras palavras, o que você faz ou precisa fazer quando obtém acesso ao alvo.

É importante saber que essas atividades nem sempre são as mesmas, dependendo do tipo de acesso que você tem, do sistema que você comprometeu e assim por diante. Isso significa que executaremos diferentes atividades, tarefas e ferramentas nos sistemas operacionais.

Além disso, você nunca deve esquecer as regras do contrato. Ao executar tarefas pós-exploração, verifique se você tem as permissões e os direitos de modificar serviços, configurações de máquina, escalar privilégios, reunir informações confidenciais, excluir logs e assim por diante.

Você deve sempre acompanhar as ações tomadas contra as máquinas comprometidas. Isso inclui data e hora, alterações feitas em documentos, serviços, aplicativos e configurações de máquinas, mas também dados privados, métodos usados para manter o acesso e assim por diante. Essa informação (contendo a lista de alterações feitas) deve ser incluída no relatório final.

Todos os dados descobertos e reunidos devem ser protegidos. Isso significa que você deve criptografá-los em sua máquina de pentest e excluí-lo permanentemente assim que o pentest for concluído. Mesmo ao relatar informações confidenciais ao seu cliente, como uma captura de tela contendo nome de usuário ou senhas, sempre ofusque e mascare os dados.

Uma das primeiras etapas que você executará depois de comprometer uma máquina é manter o acesso ou a persistência. Ele permite que você volte para a máquina sempre que quiser: geralmente um backdoor no sistema.

Ao usar esses métodos, implemente algum tipo de autenticação (para evitar que outras pessoas o usem) e exclua tudo assim que o pentest for concluído.

A pós-exploração é um processo cíclico, você pode descobrir novas redes, novos *hosts*, novos alvos e, em seguida, obter acesso a eles por meio da exploração. Além disso, observe que cada *host* comprometido pode armazenar e fornecer informações que outras pessoas não armazenam.

A fase de pós-exploração realmente permite que você se infiltre em uma rede inteira em vez de em um único host.

2 QUEBRA DE SENHA

A quebra de senha é o ato de tentar adivinhar ou decodificar senhas criptografadas. O Windows usa senhas para autenticar usuários, serviços e computadores. Aplicativos de terceiros também podem ter suas próprias senhas. As senhas podem ser encontradas em muitos locais, todos vulneráveis a ataques.

2.1 Pós-exploração Windows

Algumas senhas são armazenadas em texto não criptografado, porém, a maioria é armazenada como um valor de hash. Uma das maiores restrições para a quebra efetiva de senhas é ter a energia da CPU necessária ou um dicionário de senhas ou *rainbow table* suficientemente grande.

De uma perspectiva mais ampla, nem toda autenticação é feita por meio de senhas. Algumas credenciais são armazenadas como chaves privadas, certificados ou tíquetes Kerberos, que também podem ser direcionados. A Autoridade de Segurança Local do Windows (LSASS) usa segredos de LSA para armazenar uma variedade de senhas de usuário, serviço e aplicativo. Em alguns casos, como nos segredos Kerberos ou LSA, eles podem ser encontrados na memória após o login do usuário ou a inicialização do computador.

Desde o Windows NT 4.0, o Windows armazenou nomes de usuário e senhas locais no Security Account Manager (SAM). Essa é uma seção do registro

armazenada no disco em % WINDIR%\System32\config\SAM e carregada na memória na inicialização. As senhas são armazenadas como dois tipos de hashes:

- LanMan (LM) - antes do hash, as senhas são convertidas em maiúsculas e, em seguida, truncadas ou preenchidas para ter 14 caracteres. O valor real armazenado não é o próprio hash da senha. Em vez disso, o hash é dividido em duas partes de 7 bytes, cada uma delas usada como uma chave DES de 56 bits para criptografar a cadeia fixa "KGS! @ # \$%". O hash é suscetível a ataques de dicionário e de rainbow table.
- NT hash - Esse é um hash MD4 simples da senha (codificado como UTF-16 little endian). Não se destaca, contudo, permite senhas com até 128 caracteres.

Nos dias do NT 4.0, a Microsoft introduziu um utilitário especial chamado SYSKEY para dificultar a descryptografia de *hashes*. Os administradores o usaram para criptografar os segredos de SAM, LSA e senhas de domínio em cache.

Durante a inicialização, você pode fornecer uma senha de desbloqueio, inserir um disquete ou armazenar a chave no registro para que o computador inicialize sem nenhuma intervenção especial. Se o SYSKEY estiver armazenado no registro, ele poderá ser encontrado em quatro partes em SYSTEM\CurrentControlSet\Control\Lsa, nas subchaves JD, Skew1, GBG e Data.

Essas partes, no entanto, podem ser extraídas e usadas para gerar a chave RC4 necessária para descryptografar os hashes LM e NT. Também é possível usar um disco de inicialização especial para excluir o SYSKEY.

Existem muitas ferramentas de quebra de senha disponíveis. Muitas são multifuncionais. Algumas ferramentas, como o Hashcat, usam o poder de processamento adicional da placa de vídeo do computador (GPU). Outras, como John the Ripper, têm a capacidade de coordenar o cracking em vários computadores em rede. Aqui estão algumas técnicas e ferramentas comuns de quebra de senha do Windows:

- Hydra002E
- Medusa.
- Ncrack.

- AET2 Brutus.
- L0phtCrack.

Sistemas de arquivos do Windows – a maioria das vulnerabilidades do sistema de arquivos do Windows está relacionada a permissões definidas incorretamente. No entanto, houve outras vulnerabilidades e explorações notáveis. A seguir, estão os mais comuns.

Permissões – esse é, de longe, o maior problema de segurança relacionado ao sistema de arquivos. Por padrão, o grupo Todos pode ler um compartilhamento e o grupo Usuários pode ler uma pasta ou arquivo. Isso significa que os membros internos podem usar ferramentas como o FileLocator Pro, o Agent Ransack ou a Effective File Search para pesquisar, na rede, por arquivos com informações confidenciais. Além disso, uma ferramenta como NTFSDOS pode ser usada junto com o acesso físico à máquina para ignorar as permissões NTFS.

Você também pode usar o módulo Metasploit `post / windows / gather / file_from_raw_ntfs` para ignorar algumas restrições, como bloqueios em arquivos abertos. Isso permite que o invasor recupere arquivos que não podem ser copiados, como o banco de dados do Active Directory `ntds.dit`.

Alternate Data Streams (ADS): a Microsoft incluiu o ADS no sistema de arquivos NTFS para compatibilidade com o sistema de arquivos Macintosh HFS. No entanto, pode ser abusado porque você pode usá-lo para ocultar arquivos no sistema de arquivos. A unidade pode relatar menos espaço livre, mas os arquivos ocultos não podem ser visualizados ou listados por meios normais.

Um exemplo simples de uso do ADS é `C: \> eco "Informações super secretas"> test.txt: hidden.txt`. Isso cria um arquivo vazio chamado `test.txt`, enquanto simultaneamente cria um arquivo oculto chamado `hidden.txt`. O arquivo oculto tem a mensagem secreta. Para visualizar a mensagem secreta, você pode usar um editor de texto; por exemplo, `C: \> notepad.exe test.txt: hidden.txt`. Você pode usar isso para ocultar arquivos de vídeo inteiros, se desejar.

Você também pode usar ferramentas como os cmdlets `LADS`, `Streams` ou `PowerShell Get-Item` e `Set-Content` para criar, exibir e manipular arquivos ADS.

Unquoted Service Paths é, potencialmente, uma vulnerabilidade muito poderosa. Ela tira proveito dos caminhos de arquivo que possuem espaços nos nomes e pode ser usada para sequestrar DLLs e outros executáveis. Considere o seguinte exemplo:

```
C: \ Gaming Group \ coolgames \ mygame.exe
```

O caminho tem um espaço entre Gaming e Group. Se esse caminho não estiver entre aspas, por exemplo "C: \ Gaming Group \ coolgames \ mygame.exe", o Windows irá parar no espaço para ver se ele pode executar o nome antes do espaço. Nesse caso, o Windows tentaria iniciar um executável chamado C: \ Gaming.exe.

Uma variante disso é o DLL *hijacking*, no qual o caminho para qualquer DLL chamado pelo aplicativo pode ser abusado de maneira semelhante. Se o aplicativo for um serviço que começa com o privilégio do sistema local, sua versão mal-intencionada pode fazer praticamente qualquer coisa, porque também iniciaria com esse nível de privilégio.

Você pode procurar serviços que têm essa vulnerabilidade usando:

- Metasploit módulo de exploração/windows/local/trusted_service_path
- PowerSploit Get-ServiceUnquoted cmdlet
- WMIC consulta serviço wmic nome get, displayname, caminho, StartMode | findstr / i "auto" | findstr / i / v "c: \ windows \\" | findstr / i / v ""

Criptografia fraca ou inexistente

Historicamente, os arquivos do Windows não eram criptografados por padrão. Eles podem ter permissões que exigem privilégios de SISTEMA ou estar em um formato que você não pode abrir com um editor de texto ou ter seus dados em hash ou criptografados, entretanto, os arquivos em si não foram criptografados. Houve várias tentativas para corrigir isso:

- Criptografia NTFS – Criptografa o acesso NTFS a arquivos e pastas. Pode ser ignorado usando ferramentas como ER Commander e NTFSDOS.

- SYSKEY para criptografar o SAM – Um disco de inicialização especial, como o Ultimate Boot CD para Windows ou o Offline NT Password & Registry Editor, pode excluí-lo.
- Sistema de arquivos com criptografia (EFS) – usa várias chaves para criptografar/descriptografar arquivos. Funciona apenas nesse sistema de arquivos local. Os arquivos criptografados transmitidos pela rede ou copiados para um local não criptografado são criptografados antes de serem copiados ou enviados. Algumas ferramentas comerciais também despejam o arquivo da memória. Se o sistema travar enquanto você estiver trabalhando em um arquivo criptografado, uma versão em texto não criptografado será salva no despejo de memória.
- BitLocker – Criptografa a unidade inteira. Os arquivos na unidade permanecem criptografados, mesmo em uso. Os dados dos arquivos, no entanto, são descriptografados à medida que são carregados na memória. Existem ferramentas forenses comerciais que podem ser usadas para despejar o conteúdo carregado da RAM.

Vulnerabilidades de código

Aqui estão algumas vulnerabilidades de código comuns:

- Exploração de DoS da tabela de arquivos mestre do NTFS 3.1 – Atualmente, não há CVE. Isso explora uma vulnerabilidade na tabela de arquivos mestre do Windows. HTML especialmente criado fará com que um navegador tente acessar um arquivo inexistente. O navegador travará e, em seguida, todo o sistema deixará de responder. Afeta o Windows XP - 8.1. <https://www.exploit-db.com/exploits/42253/>.
- Escalação de desvio de privilégio de proprietário / rótulo obrigatório do Windows NTFS da exploração de privilégios – CVE-2018-0748. Contorna as verificações de segurança, permitindo que um usuário não administrador defina o descritor de segurança em um arquivo com valores não padrão. <https://www.exploit-db.com/exploits/43514/>.
- Exploração de DoS do Windows NTFS – Atualmente, não há CVE. Essa exploração gera uma tela azul da morte usando uma imagem NTFS

artesanal. Afeta o Windows XP a 10, Server 2012 R2.
https://github.com/mtivadar/windows10_ntfs_crash_dos.

Vulnerabilidades no kernel do Windows

O kernel do Windows (ntoskrnl.exe) é a parte principal do sistema operacional. Suas funções incluem gerenciar memória, agendar threads para execução na CPU, controlar E/S do dispositivo e outras tarefas. Ele roda no nível mais privilegiado da CPU (anel 0) e tem prioridade sobre todos os outros processos.

Explorações que atacam o kernel são extremamente poderosas. Elas aumentam seu privilégio, mas também podem desestabilizar o sistema. As ameaças persistentes avançadas (APTs) usam vulnerabilidades do kernel para manter seus malwares ocultos. O código malicioso que é executado no kernel é difícil de detectar e ainda mais difícil de se livrar. O GitHub lista mais de 50 explorações de kernel do Windows para download. Uma plataforma de kernel de consulta de pesquisa Metasploit: windows retorna cerca de 20 resultados.

Escalonamento de privilégios no Windows

O escalonamento é um dos principais objetivos de qualquer exploração. Permite ao invasor obter controle, acessar/alterar arquivos confidenciais e deixar backdoors permanentes. Durante um pentest, você raramente terá acesso administrativo a um sistema de destino em sua primeira tentativa. Você precisará encontrar uma maneira de elevar seu acesso ao administrador e, depois, (esperançosamente) ao nível do SISTEMA.

Além das explorações específicas do kernel, existem outros tipos de explorações que podem elevar privilégios. Elas aproveitam os serviços, drivers e aplicativos em execução no privilégio SYSTEM ou administrador. Como as explorações do kernel, a maioria é executada localmente depois que você obtém acesso ao destino.

Configurações padrão no Windows

As configurações padrão têm uma coisa em comum: são previsíveis e, portanto, podem ser estudadas quanto a vulnerabilidades. Muitas explorações dependem de sistemas com padrões não corrigidos. No passado, o Windows era fornecido com padrões menos restritivos, mais fáceis de explorar. Por exemplo, as

senhas de administrador podem ser simples (ou mesmo em branco) e não expirar. Serviços desnecessários, como o IIS, foram instalados por padrão, às vezes, com consequências desastrosas. Um dos exemplos mais notáveis foi o IIS 5.0, que fazia parte de qualquer instalação padrão do Windows Server 2000. Permitiu a passagem de diretório, vazamento de informações, escalonamento de privilégios e execução arbitrária de códigos – tudo por meio da URL de um navegador. Esse padrão ajudou a espalhar o infame nimda worm, um dos vírus de computador mais rápidos e caros de todos os tempos.

Ao longo dos anos, a Microsoft mudou suas configurações padrão de mais permissivas para mais restritivas. No entanto, todas as instalações padrão devem ser seguidas aplicando patches e políticas de segurança adicionais. Nem todos os administradores fazem isso. Em alguns casos, as configurações padrão são flexíveis para permitir compatibilidade com versões anteriores ou funcionalidade extra, especialmente para aplicativos herdados que não podem ser atualizados.

Os padrões vulneráveis que ainda persistem incluem:

- Serviços desnecessários – As instalações padrão do Windows sempre incluíram serviços de que você talvez não precise. Use o seguinte arquivo para identificar e desativar serviços desnecessários: msconfig.exe.
- Serviço de obtenção do PowerShell | cmdlets fl e set-service.
- Suporte para SMB v1.0 – Esse protocolo fraco de arquivo e impressão foi objeto de muitas explorações, sendo a mais recente a EternalBlue. Ele ainda é fornecido com todos os sistemas operacionais Windows, incluindo o Server 2016.
- Cache da senha da conta de domínio – As credenciais do usuário do domínio que foram armazenadas em cache na máquina local podem ser despejadas e usadas por um invasor.
- Contas padrão – Contas como administrador, convidado, krbtgt e outras pessoas têm IDs de segurança (SIDs) que não podem ser alteradas. Isso os torna um alvo para despejar hashes e passar o hash.
- Registro de segurança padrão – O registro de segurança do Windows não inclui acesso confidencial a arquivos / pastas. Além disso, os tamanhos

dos arquivos de log geralmente são pequenos demais para uma organização corporativa e o log não é encaminhado automaticamente para um servidor central. Todas essas coisas tornam mais fácil para um invasor passar despercebido ou cobrir seus rastros.

3 PÓS-EXPLORAÇÃO LINUX

Vulnerabilidades no sistema operacional Linux, o nome "Linux", na verdade, se refere ao kernel do sistema operacional. O DistroWatch.com relata que existem (até agora) quase 800 distribuições ou distribuições Linux desde 2001. Algumas são produtos comerciais, embora a grande maioria seja desenvolvida e mantida pela comunidade de código aberto. Muitos não existem mais. Como existem grandes variações nos recursos de distribuição, também existem grandes variações nas vulnerabilidades entre os produtos. Muitas vulnerabilidades são introduzidas devido aos serviços e aplicativos adicionados à instalação principal.

As vulnerabilidades do Linux se enquadram nas mesmas categorias principais encontradas no Windows. A lista a seguir mostra as principais vulnerabilidades em ordem decrescente:

- DoS.
- Revelação de informações.
- Estouros de buffer ou heap.
- Escalonamento de privilégios.
- Execução remota de código.
- Corrupção de memória.
- Desconhecimento de recurso de segurança.
- Passagem de diretório.

Permissões do Linux são mais diretas e menos complexas que suas equivalentes no Windows. Existem vários tipos de arquivos:

- - = Arquivo normal.

- d = Diretório (pasta).
- l = Link simbólico.
- b = Bloquear dispositivo especial.
- c = Dispositivo de caractere.
- s = Soquete Unix.
- p = Pipe nomeado.

Você pode visualizar permissões digitando `ls -l`. Cada arquivo terá apenas três tipos de entidades que podem acessá-lo:

- Usuário (u) – o proprietário do arquivo
- Grupo (g) – qualquer usuário no grupo do arquivo
- Outro (o) – todo mundo

Cada entidade pode ter três permissões, qualquer uma das quais também pode ser definida como nenhuma (-):

- r - ler
- w - escrever
- x - executar (se definido em um diretório, você pode inserir o diretório e listar seu conteúdo). Exemplos:
 - `rw-rw-rw-` = usuário, grupo e outros. todos têm permissões completas.
 - `rw-r--r--` = o usuário possui permissões totais, o grupo pode ler e executar, todos os outros podem ler, apenas.

Cada entidade (u, g, o) tem suas três permissões somadas em um único número:

- r = 4
- w = 2
- x = 1
- - = 0

Aqui estão alguns exemplos. Ambos são arquivos regulares, conforme indicado pelo primeiro caractere, que é um "-".

- `-rwxrwxrwx = 777` – O usuário tem r, w, x, que é igual a $4 + 2 + 1 = 7$. Grupo e Outro também têm as mesmas permissões.
- `-rwxr-xr-- = 754` – O usuário possui r, w, x, que somam 7, mas o grupo possui apenas r, x, que somam 5, e Outros apenas possui r, que é 4.

Permissões exemplo

O exemplo a seguir tem estas configurações:

- É um diretório chamado Desktop.
- O usuário pode ler, escrever e executar (digite o diretório para listar seu conteúdo).
- O grupo pode ler e executar, todavia, não pode modificar.
- Outros podem ler e executar, porém, não podem modificar.
- É de propriedade do root e qualquer pessoa no grupo raiz tem as permissões no nível do grupo (rx), embora o próprio usuário *root* tenha permissões completas (rwx).
- Outra maneira de escrever as permissões é 755.

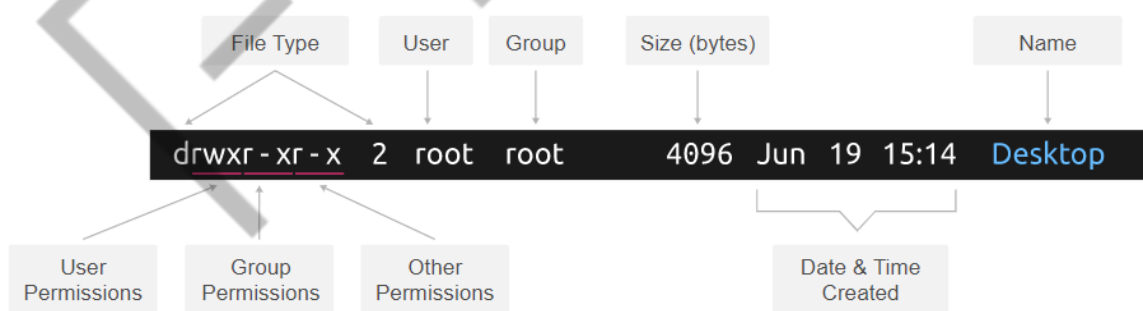


Figura 1 - Permissões
Fonte: Elaborado pelo autor (2019)

Definindo permissões

Você pode atribuir permissões com o comando `chmod`. Por exemplo:

`chmod 777 myfile` = todos podem ler, escrever e executar myfile.

`chmod 644 myfile` = usuário rw, grupo r, outro r.

chmod 740 myfile = usuário rwx, grupo r, outros não podem fazer nada.

Permissão especial bits

Linux também tem bits de permissão especiais que são de interesse para o atacante:

setuid (SUID) – conjunto ID de usuário após a execução;

setgid (SGID) ID de grupo – conjunto após a execução;

sticky – somente o root ou proprietário do arquivo pode mudar arquivos no diretório.

Setuid

Quando um arquivo é executado, ele assume as permissões do usuário que o iniciou, não do proprietário que o criou. Isso significa que um processo pode apenas ler/gravar/executar para o que o usuário tem permissão. Se você deseja conceder temporariamente a outros usuários as mesmas permissões que o proprietário, é possível ativar o bit SUID nesse arquivo. Isso permite que o processo seja executado como proprietário, e não como o usuário que acabou de iniciar o processo. Como exemplo, digamos que você tenha criado um script com essas permissões:

```
-rwxr - r--
```

No momento, somente você (o proprietário) pode executá-lo. Todos os outros (incluindo o grupo) podem lê-lo, mas não podem executá-lo. Você deseja que os técnicos de suporte técnico também possam executar esse script. Você pode permitir que eles efetuem login / sudo como você (má ideia, pois não deseja que eles saibam sua senha) ou pode alterar as permissões do grupo e colocá-las no grupo (pode causar problemas com outros arquivos) ou pode ativar o bit SUID para que, quando eles iniciem esse script, ele seja executado no seu nível de privilégio e realmente seja executado. Você configura o SUID substituindo o x do proprietário por s. Portanto, as permissões agora teriam a seguinte aparência:

```
-rwsr - r--
```

Você pode definir o bit SUID em um arquivo com este comando: `chmod u + s myfile`. Você pode removê-lo com:

```
chmod us myfile.
```

A ativação do SUID em executáveis corre o risco de permitir que um invasor execute esse executável como seu proprietário (que pode ser root!). Para encontrar programas com o conjunto de bits SUID, digite `sudo find / -perm -4000`.

Setgid

Semelhante ao SUID, você pode ativar o bit SGID para que um arquivo possa ser executado no nível de privilégio do grupo, em vez do grupo principal do usuário. Por exemplo, o grupo do arquivo pode ser administrador, mas o grupo do usuário pode ser de vendas. Talvez você não queira alterar alguém do grupo de vendas, mas deseja que ele execute esse arquivo como membro do grupo de administradores. Setgid também tem outro comportamento se definido em um diretório: todos os arquivos dentro do diretório teriam as permissões do grupo. Você ativa o bit SGID nas permissões do grupo, não as permissões do usuário:

```
-rwxr-sr--
```

Para ativar o SGID, insira `chmod g + s ourfile`. Para removê-lo, digite `chmod gs ourfile`. Para encontrar programas com o conjunto de bits SGID, digite `sudo find / -perm 2000`.

Bit Sticky

Definir o bit sticky protege os arquivos em um diretório comum, como `/ tmp` ou `/ home`. Se você definir `drwxrwxrwx` em `/ home`, todos poderão excluir ou renomear os arquivos um do outro. Se você definir o ponto fixo, as pessoas poderão modificar apenas seus próprios arquivos. O usuário `root`, é claro, ainda pode modificar os arquivos de todos. O diretório `/tmp` tem o bit fixo definido por padrão.

Para definir o bit adesivo, execute este comando: `chmod + t <nome do diretório>`. Isso anexa um "t" ao final das permissões:

```
drwxrwxrwxtdesivo
```

Remova o bitcom o comando `chmod -t <nome do diretório>`.

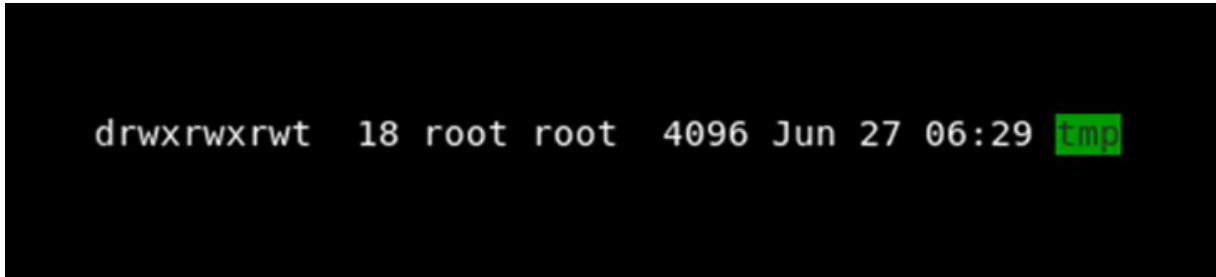


Figura 2 - Bit Sticky
Fonte: Elaborado pelo autor (2019)

No Linux, como em qualquer sistema operacional, os pacotes de software que você baixa e instala terão configurações padrão. Embora o risco de segurança dos padrões dependa do produto e do fornecedor, muitas instalações apresentam vulnerabilidades por padrão ou são posteriormente configuradas incorretamente pelos administradores. Aqui estão algumas configurações padrão comuns do Linux, que aumentam a vulnerabilidade geral do sistema:

- Permissões pessoais do usuário – A permissão padrão em uma pasta pessoal é 775, o que significa que qualquer pessoa que possa acessar o servidor pode visualizar o conteúdo dos diretórios pessoais de outros usuários. Isso pode incluir scripts de desenvolvedor, arquivos de backup do administrador, listas e chaves de senha ou outros documentos confidenciais.
- Diretórios / arquivos legíveis por mundo e graváveis por mundo – Quando um arquivo é criado, o umask padrão é 022 (permissão 644), o que significa que todos podem ler o arquivo, embora apenas o proprietário possa gravá-lo.
- Opções de montagem ou exportação inseguras – O padrão para pontos de montagem (diretórios que apontam para outro sistema de arquivos) inclui `rw`, `suid`, `dev`, `exec`, `auto`, `nouser` e `async`. Essas opções permitem que os usuários criem arquivos nos compartilhamentos NFS como se fossem raiz, resultando na divulgação de informações e na escalção de privilégios.
- Serviços e aplicativos com padrões fracos – Também é comum encontrar serviços e aplicativos recém-instalados que usam protocolos de

comunicação menos seguros e senhas padrão, escutando em todas as interfaces.

4 DADOS CONFIDENCIAIS

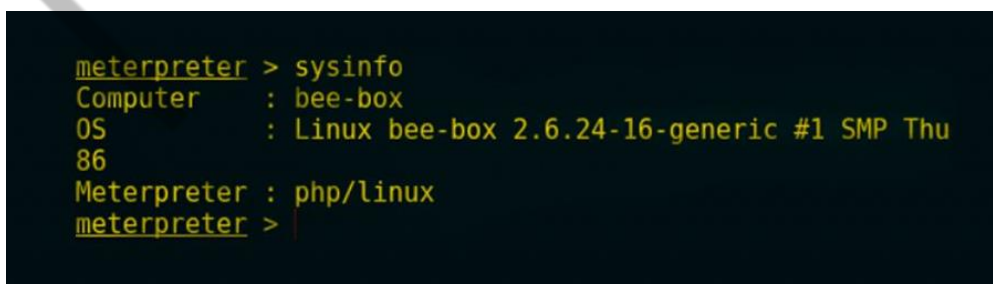
Pillaging é a etapa na qual você acessa dados confidenciais e propriedade intelectual da organização-alvo. Demonstrar a viabilidade de um *hacker* externo acessar essas informações pode ser o objetivo do engajamento geral, portanto, essa fase é fundamental.

4.1 Pilaging

No entanto, de acordo com o tipo de máquina que você comprometeu, você pode ou não encontrar o que está procurando. Isso apresenta a necessidade de explorar e de se infiltrar na rede.

Portanto, nesta etapa, também colheremos dados e informações necessários para essa finalidade.

Com o comando `sysinfo`, podemos obter informações básicas sobre o sistema remoto. Observe que o *script* funciona nos sistemas operacionais Windows e Linux, claro você já precisa ter explorado uma vulnerabilidade e ter acesso à máquina alvo via `meterpreter`.



```
meterpreter > sysinfo
Computer      : bee-box
OS            : Linux bee-box 2.6.24-16-generic #1 SMP Thu
86
Meterpreter   : php/linux
meterpreter >
```

Figura 3 - sysinfo

Fonte: Elaborado pelo autor (2019)

Outro comando que podemos usar é o `getuid`. Com ele, podemos verificar o usuário que estamos executando como na máquina de destino.

```
meterpreter >  
meterpreter > getuid  
Server username: NT AUTHORITY\LOCAL SERVICE  
meterpreter >
```

Figura 4 - getuid
Fonte: Elaborado pelo autor (2019)

A partir dessas informações, já podemos começar a supor o papel da máquina vítima. Por exemplo, se o comando anterior nos mostrar que a máquina vítima é um servidor, uma das coisas mais importantes a verificar é quais serviços estão sendo executados nela. Em outras palavras, temos que descobrir o papel da máquina na rede remota.

Vamos começar a descobrir alguns dos comandos que podemos executar para coletar mais informações.

```
meterpreter > run post/windows/gather/enum_services  
[*] Listing Service Info for matching services, please wait...  
[+] New service credential detected: AeLookupSvc is running as 'localSystem'  
[+] New service credential detected: ALG is running as 'NT AUTHORITY\LocalService'  
[+] New service credential detected: aspnet_state is running as 'NT AUTHORITY\NetworkService'  
Services  
=====
```

Name	Credentials	Command	Startup
ALG	NT AUTHORITY\LocalService	Manual	C:\Windows\System32\alg.exe
AeLookupSvc	localSystem	Manual	C:\Windows\system32\lsass.exe
AppIDSvc	NT Authority\LocalService	Manual	C:\Windows\system32\lsass.exe
Authentication			
AppMgmt	LocalSystem	Manual	C:\Windows\system32\lsass.exe
Appinfo	LocalSystem	Manual	C:\Windows\system32\lsass.exe
AudioEndpointBuilder	LocalSystem	Auto	C:\Windows\System32\lsass.exe

```
ected
```

Figura 5 - enum_service
Fonte: Elaborado pelo autor (2019)

Como podemos ver, com um único comando, obtemos uma lista de todos os serviços na máquina remota, o usuário associado a cada um deles, o tipo de inicialização e o caminho para o binário.

Também podemos facilmente verificar os processos em andamento com o comando ps. O resultado é semelhante em ambiente Windows e Linux.

```
meterpreter > ps

Process List
=====
```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]		4294967295		
4	0	System	x86	0		
272	4	smss.exe	x86	0	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
364	348	csrss.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
416	348	wininit.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wininit.exe
424	408	csrss.exe	x86	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
472	408	winlogon.exe	x86	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\winlogon.exe
508	516	TPAutoConnSvc.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Program Files\VMware\VMware Tools\TPAutoConnSvc.exe
516	416	services.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\services.exe
532	416	lsass.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe
540	416	lsm.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsm.exe
648	516	svchost.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svchost.exe
724	516	svchost.exe	x86	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\system32\svchost.exe
764	516	MsMpEng.exe	x86	0	NT AUTHORITY\SYSTEM	c:\Program Files\Microsoft Security Client\MsMpEng.exe
908	516	svchost.exe	x86	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\system32\svchost.exe
948	516	svchost.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svchost.exe
996	516	svchost.exe	x86	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\system32\svchost.exe
1036	516	svchost.exe	x86	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\svchost.exe
1064	1036	wuauclt.exe	x86	1	CORP\Administrator	C:\Windows\system32\wuauclt.exe

Figura 6 - PS

Fonte: Elaborado pelo autor (2019)

Outro ponto muito importante é a enumeração e o comando run winenum, que efetua uma varredura completa na máquina e traz vários itens importantes, como pastas, usuários, grupos, sessões GPOs etc.

```
meterpreter > run winenum
[*] Running Windows Local Enumeration Meterpreter Script
[*] New session on 192.168.155.130:1031...
[*] Saving report to /home/laughingman/.msf3/logs/winenum/192.168.155.130_20091109.3318-98038/192.168.155.130_20091109.3318-98038.txt
[*] Checking if VICTIM-CLIENT is a Virtual Machine .....
[*] BIOS Check Failed
[*] This is a VMware virtual Machine
[*] Running Command List ...
[*] running command cmd.exe /c set
[*] running command arp -a
[*] running command ipconfig /all
[*] running command ipconfig /displaydns
[*] running command route print
[*] running command net view
[*] running command netstat -nao
[*] running command netstat -vb
[*] running command netstat -ns
[*] running command net accounts
[*] running command net accounts /domain
[*] running command net session
[*] running command net share
[*] running command net group
[*] running command net user
[*] running command net localgroup
[*] running command net localgroup administrators
[*] running command net group administrators
[*] running command net view /domain
[*] running command netsh firewall show config
[*] running command tasklist /svc
[*] running command tasklist /m
[*] running command gpresult /SCOPE COMPUTER /Z
[*] running command gpresult /SCOPE USER /Z
[*] Running WMIC Commands ....
[*] running command wmic computersystem list brief
[*] running command wmic useraccount list
```

Figura 7 - Winenum

Fonte: Elaborado pelo autor (2019)

Não podemos esquecer que, na maioria das vezes, a máquina alvo da vítima está ligada e, provavelmente, seu usuário está acessando algo, portanto podemos também iniciar um keylogger, esperando algum tempo para termos uma saída com possíveis dados sigilosos.

```
meterpreter > keyscan_start
Starting the keystroke sniffer...
meterpreter > keyscan_dump
Dumping captured keystrokes...
  tgoogle.cm my credit amex  myusernamthi    amexpasspasswordpassword
```

Figura 8 – Keylogger
Fonte: Elaborado pelo autor (2019)

REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014

WILHELM, T. **Professional Penetration Testing**: Creating and Learning in a Hacking Lab. 2. Waltham, MA: Syngress, 2013.